

Artificial Intelligence (AI)

Introduction

Artificial Intelligence (AI) has rapidly evolved from a niche technology into a cornerstone of modern innovation, driving advancements across industries such as healthcare, finance, manufacturing, and cybersecurity. While AI offers transformative benefits enhancing efficiency, decision making, and predictive capabilities it also introduces significant risks and threats that organisations must address proactively. These challenges range from adversarial attacks and data poisoning to ethical concerns, privacy violations, and the exploitation of AI systems by malicious actors.

As AI systems become more integrated into our infrastructure and business processes, their vulnerabilities can have far reaching consequences, including operational loss and reputational damage. Understanding these risks is essential for developing robust security strategies that safeguard AI models, data pipelines, and operational environments.

This document explores the key risks and threats associated with AI technologies and provides actionable security recommendations to mitigate these challenges. By adopting a comprehensive approach to AI security, organizations can harness the benefits of AI while minimising exposure to emerging threats in an increasingly complex digital landscape.



Risks

Data Integrity Risks

Description: AI models rely heavily on large datasets for training and inference. Compromised or poisoned data can lead to inaccurate predictions or biased outcomes.

Examples: Data poisoning attacks, insertion of malicious samples, incomplete or skewed datasets.

Model Vulnerabilities

Description: AI models can be exploited through adversarial inputs or reverse engineering, exposing intellectual property and enabling malicious manipulation.

Examples: Adversarial attacks, model inversion, extraction of proprietary algorithms.

Privacy Risks

Description: AI systems often process sensitive personal or organizational data, creating risks of unauthorised access or leakage.

Examples: Re-identification of anonymised data, inference attacks, exposure of confidential information.

Operational Risks

Description: Integration of AI into critical systems introduces risks of system failure, misconfiguration, or unintended consequences.

Examples: Autonomous decision errors, cascading failures in automated workflows.

Ethical and Bias Risks

Description: AI models may perpetuate or amplify biases present in training data, leading to unfair or discriminatory outcomes.

Examples: Algorithmic bias in hiring, lending, or law enforcement applications.

Supply Chain Risks

Description: AI components sourced from third parties may contain vulnerabilities or backdoors, compromising security.

Examples: Malicious code in pre-trained models, compromised libraries or frameworks.

Regulatory and Compliance Risks

Description: Failure to comply with evolving AI governance frameworks and data protection laws can result in legal and financial penalties.

Examples: SOCI violations, non-compliance with AI ethics standards.

Threat Actor Exploitation

Description: Cybercriminals and nation state actors may weaponize AI for attacks such as deepfake videos, vishing, automated phishing, or enhanced malware.

Examples: AI driven social engineering, synthetic identity fraud.

AI within BSL

The below are some of the ways AI could potentially be used within BSL.

UC1: Generative AI LLM Development

Building large language models (LLMs) from scratch or fine-tuning existing models to meet organizational needs. This involves training on massive datasets to enable natural language understanding and generation for tasks like content creation, summarization, and conversational interfaces.

UC2: Using Known Context with an Already trained LLM

Leveraging pre-trained LLMs and enriching them with organization specific context (e.g., policies, procedures, proprietary data) to deliver accurate, domain-relevant outputs without retraining the entire model.

UC3: Gen AI Embedded into SaaS Solutions

Using generative AI capabilities available within a Software-as-a-Service platforms to enhance functionality. Examples include automated document drafting in productivity tools, intelligent customer support in CRM systems, and AI-driven analytics in business applications.

UC4: Agentic AI agent within a Platform

Deploying autonomous AI agents inside a platform to perform tasks proactively. These agents can plan, execute, and adapt workflows without constant human intervention, improving efficiency and reducing operational overhead.

UC5: Agentic AI Communicating with Another Agentic AI

Creating ecosystems where multiple AI agents collaborate or negotiate with each other to achieve complex objectives. This enables distributed decision-making, dynamic resource allocation, and multi-agent problem-solving across interconnected systems.

Security Guideline

Use Case	Security Capability	Control
UC1/UC2/UC3 /UC4/UC5	Data Protection	BSL User PII, Customer PII or Intellectual Property (IP) information must not be used to train an LLM.
UC1/UC2/UC3 /UC4/UC5	Data Protection	Ensure datasets are clean, accurate, and free from malicious or biased content.
UC1/UC2/UC3 /UC4/UC5	Data Protection	Restrict access to training data and enforce least privilege principles.
UC1/UC2/UC3 /UC4/UC5	SDLC	Incorporate security reviews and threat modeling throughout the AI development process.
UC1/UC2/UC3 /UC4/UC5	SDLC	Test models against adversarial inputs to identify vulnerabilities.
UC1/UC2/UC3 /UC4/UC5	SDLC	Maintain secure repositories for model code and configurations.
UC1/UC2/UC3 /UC4/UC5	Authorization	Limit who can train, deploy, and modify models.
UC1/UC2/UC3 /UC4/UC5	Authentication	Secure access to AI development environments.
UC1/UC2/UC3 /UC4/UC5	Logging	Log all model training and deployment activities for accountability.
UC1/UC2/UC3 /UC4/UC5	Backup and Restoration	Enable quick restoration to secure versions of models.

UC1/UC2/UC3 /UC4/UC5	Monitoring	Monitor for unusual behavior in model outputs or resource usage.
UC1/UC2/UC3 /UC4/UC5	SDLC	Verify integrity of pre-trained models, libraries, and frameworks.
UC1/UC2/UC3 /UC4/UC5	SDLC	Regularly check for vulnerabilities in open-source packages.
UC1/UC2/UC3 /UC4/UC5	SDLC	Ensure adherence to AI ethics, privacy laws and BSL policies.
UC1/UC2/UC3 /UC4/UC5	SDLC	Document model decisions and maintain interpretability.
UC1/UC2/UC3 /UC4/UC5	SDLC	Regularly inspect and test the app using tools and techniques like SAST (Static Application Security Testing), DAST (Dynamic Application Security Testing), and IAST (Interactive Application Security Testing). These tests will identify potential vulnerabilities or weak points in the app.
UC1/UC2/UC3 /UC4/UC5	Input/Output Filtering	Validate and sanitize input context to prevent injection of malicious or misleading data.
UC1/UC2/UC3 /UC4/UC5	Input/Output Filtering	Only use prompts created/vetted by creating standard prompt templates.
UC1/UC2/UC3 /UC4/UC5	Input/Output Filtering	Apply strict filtering for sensitive information including PII data, credentials or access keys before passing it to/from the LLM as request or response.
UC1/UC2/UC3 /UC4/UC5	Input/Output Filtering	Block injection attempts (e.g., prompt injection attacks) that override system instructions or extract sensitive data.
UC1/UC2/UC3 /UC4/UC5	Data Encryption	Encrypt contextual data both in transit (TLS) and at rest using strong cryptographic standards.
UC1/UC2/UC3 /UC4/UC5	Secure Integration	Secure API calls between context sources and the LLM with mutual TLS or token-based authentication.
UC1/UC2/UC3 /UC4/UC5	Input/Output Filtering	Integrate redaction mechanisms to automatically identify and remove sensitive information from model outputs.

UC1/UC2/UC3 /UC4/UC5	Input/Output Filtering	Use AI content moderation tools to detect and block harmful or confidential data in outputs.
UC1/UC2/UC3 /UC4/UC5	Context Lifecycle	Define retention policies for contextual data and ensure timely deletion after use.
UC1/UC2/UC3 /UC4/UC5	Context Lifecycle	Regularly review and update context sources to avoid stale or inaccurate information.
UC1/UC2/UC3 /UC4/UC5	Human in the Loop	For action impacting safety must require human review before publishing or acting on LLM-generated content enriched with sensitive context.
UC1/UC2/UC3 /UC4/UC5	Data Protection	Block connectivity all other third-party connectors and data sources.
UC3	Data Protection	AI service in a COTS solution must use only the data stored within its platform.
UC3	Data Protection	Implement DLP rules to monitor and block sensitive data leaving the environment.
UC3	Data Protection	AI service in a COTS solution must not use PII Data stored within its platform.
UC3	Data Protection	AI service in a COTS solution must be able to blacklist certain prompts to be in line with BSL policies and standards
UC4	Data Protection	Agentic AI must only reference to contextual reference from a whitelisted list of Trusted sources.
UC4	Data Protection	Agentic AI must only be granted access to the data its required access to.
UC4	Data Protection	Agentic AI must always be authenticated by a user or a service using OAUTH based authentication
UC5	Authenticatio n	Assign unique identities to each agent.
UC5	Authenticatio n	Use mutual authentication (e.g., signed tokens or certificates) for agent-to-agent communication.
UC5	Authorization	Apply RBAC to restrict what each agent can request or execute.

UC5	Data Encryption	Encrypt all inter-agent traffic using TLS.
UC5	Data Validation	Enforce protocol integrity (e.g., JSON schema validation) to prevent injection attacks.
UC5	Input/Output Filtering	Validate all exchanged messages for malicious content or prompt injection attempts.
UC5	Input/Output Filtering	Apply content moderation filters for harmful instructions.
UC5	Input/Output Filtering	Strip sensitive context before sharing between agents.
UC5	Input/Output Filtering	Define scope of authority for each agent (e.g., read-only vs. execution).
UC5	Logging	Log all agent-to-agent interactions for audit and anomaly detection.